The Basics Are Hard: Why Security Fundamentals Can be Challenging and What You Can Do About It

trimarcsecurity.com/hub-post/the-basics-are-hard-why-security-fundamentals-can-be-challenging-and-what-you-can-do-about-it

Christina Morillo June 17, 2021

Updated: Dec 13, 2024

When it comes to cybersecurity, security researchers and consultants have advised companies to do the basics/fundamentals for years. It sounds simple enough:

- Make sure you are keeping all your software up to date - Must have a patch management plan - also, monitor Microsoft's "Patch Tuesday" for important updates.
- Maintain adequate access controls – ensure that only those who require access, have access.
- Maintaining proper asset management – know what systems you have connected and what software versions are in use.
- Employee training and awareness – employees need to have an idea of the threats that are out there.
- Back-ups must have back-ups (testing the backup and recovery process is the important part).
- Don't forget to enable MFA
- Establish an information security plan, incident response plan, business continuity plan, and other related policies.

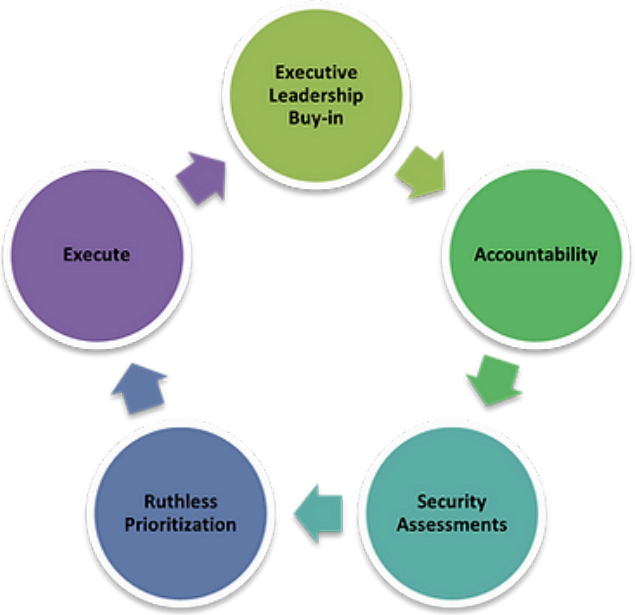
The fundamentals always sound simple and obvious; however, many barriers can make them impossible to accomplish. Information security practitioners should be mindful of the ever-evolving complexities and meet organizations where they are - to help them move forward.

One key example is MFA. As necessary as enabling MFA is, a change that affects the whole company can become much more difficult, if not impossible, without leadership's full support. Another challenge enterprises often face is trying to identify the owners of applications and data. Even upgrading systems for most companies is a long, multi-year project which can be overwhelming. I think you get where I am going here. Competing requirements, business impact, politics, lack of accountability, and zero buy-in from business leaders, including C-level executives, can make doing "the basics" much more difficult. Furthermore, if your technology and information security leaders are unwilling to

fight these good fights, we all know how that turns out in the end. Furthermore, if the company culture has a habit of wanting to know “who made the change that caused the problem to call them out”, then no one is eager to try to improve things in order to avoid being “the one” who took the critical system offline that cost the company five million dollars!

Business leaders must ask themselves what it will take to make their company resilient in today's rapidly changing threat landscape. Research shows that implementing new cybersecurity technology is relatively easy but working with people to adopt and uphold the technology can be challenging. Ultimately, many organizations end up with lots of tools that are only partially utilized (20-30% of capability) due to lack of focus on the people who work there.

So, where do we begin? Before you begin deploying new tools and solutions, you must start at the top.



Executive Leadership Buy-in

Executive leadership will need to be on board with information security as a core business function. The Information Security Executive Team, CISO, and CIO will need buy-in, support, and funding from the company's C-Level executives, the board, and other business leaders before they can start implementing company-wide controls. These mandates must come from the top. Key to this happening is constant communication to continue this feedback loop.

Accountability

The company's executives will need to establish accountability for information security risks across the organization. Formalizing roles and responsibilities, providing clarity and clear expectations from business owners, and providing guidance as needed is a great

start. If roles and responsibilities are not well defined, then things are missed. Regular communication among the people with these roles is important to ensure everyone is “on the same page”.

Security Assessments

Security assessments are one of the best tools to help identify and evaluate risks and gaps in information security. This tool acts as an excellent method to baseline your organization’s security posture. Identifies vulnerabilities, such as misconfiguration and poor patching, which threats are known to exploit. Provides an understanding of your organization’s protections against threats. Establishes a pathway to remediate and mitigate risk to your environment.

Security assessment examples include the following:

- **Compliance/Audit Review :** A form or interview which involves requesting system information from the administrators which checks for configuration based on set criteria, typically regulation (PCI, HIPPA, etc.).
- **Penetration Testing:** An authorized simulated attack focused on finding vulnerabilities in a system or network.
- **Red Teaming:** Similar to Penetration Testing as it is a simulated system attack, but Red Teaming focuses on testing an organization’s ability to detect and respond to an attack. This typically involves simulating specific attacker activity (such as an Advanced Persistent Threat, or “APT”) with broader scope and typically longer engagement timelines.
- **Trimarc Security Assessment:** An in-depth security evaluation of a specific system (such as Active Directory, Azure AD/Microsoft Office 365, VMWare) that involves leveraging a proprietary assessment methodology and tools to discover security issues unique to customer’s environment. The resulting analysis provides detailed, feasible recommendations to remediate and mitigate the identified issues. Trimarc’s security assessments blend operational and security knowledge, including in-depth subject matter expertise, to contextualize the impact of security issues as well as present remediation timelines which results in a clear roadmap to improve the system security posture.

They also help establish a benchmark for future assessments. Use this as part of your toolkit as you look to prioritize critical focus areas. This happens to be one of our specialties at Trimarc Security, give us a shout if you have any questions.

Ruthless Prioritization

One of my former managers told me once that we cannot boil the ocean. It is impossible to do everything, which means prioritizing which security needs you should focus on for your company. Senior leadership must prioritize the most important things for the teams to work on. It is also vital that the CISO and executive leadership understand how much has been invested in information security over time, which assets have current risks requiring remediation, identifying gaps in protection against threats, and overall impact against competing business priorities.

Execute

Once you have executive buy-in, accountability, a baseline security assessment, and have prioritized tasks and level of effort, it is time to execute. We have repeatedly seen many security teams ignore or miss the previous steps, which severely impedes their ability to enforce any of these fundamental controls successfully. An example of this is when the security team deploys a new security capability that will mitigate a technique that attackers are leveraging, but senior leadership didn't fully understand or buy-in on the deployment. When people in the organization start complaining about the new security capability adding steps to their process (and time!), leadership tells the security team to roll back the new capability. An important part of execution is communicating the benefits of the new capability and while it may increase time to complete some tasks, will help keep the organization out of the news when the headline is "Cyberattack on Company X" or "Ransomware hits another organization where they are forced to pay millions".

"*If you fail to plan, you plan to fail" – Ben Franklin.*

Organizations are often so focused on the technical aspects that they miss out on what makes these initiatives successful - people, processes, and plans. A robust information security program includes an aligned execution strategy, and equally important, a reporting and feedback loop. Pilot testing can help identify potential issues early to limit large scale issues later which impedes broader deployment.

The goal of the reporting and feedback loop is to surface vulnerabilities, weaknesses and educate leadership about threats to the organization as soon they are discovered. This information is then communicated to executives, which can make decisions about funding efforts related to the specific priority area. Regular meetings with executive leadership ensure that everyone is on the same page relative to the company's priorities for information security and overall resiliency and their role in achieving them.

I recently came across a post where a CIO did not believe a firewall was necessary because "there was no interesting data to protect." Yet another example that showcases a lack of understanding around fundamentals and why overall alignment is a critical component of any organization's security strategy. This is where asset discovery and

management is critical – not just identifying what's being used, but how it's being used, and tagging certain assets as "mission critical" or "proprietary/sensitive".

The fundamentals are essential; however, the implementation strategies, timelines, and priorities will look different for every organization. We need to encourage and help organizations find a way through these storms by sharing clear, helpful, and tactical guidance, not could have, would have, should have scenarios.



Microsoft Cloud Security Assessment (MCSA) Lead at Trimarc Security

Trimarc provides leading expertise in security solutions including security reviews, strategy, architecture, and implementation. Our methodology leverages our internal research and custom tooling which better discovers multiple security issues attackers could exploit to compromise the environment. Trimarc security services fit between traditional compliance/audit reviews and standard penetration testing/red teaming engagements, providing deep understanding of Microsoft and Virtualization technologies, typical security issues and misconfigurations, and provide recommendations based on our own best practices custom-tailored to balance operational and security challenges.

How to contact Trimarc:

By phone (202) 587-2735